تقرير فحص الثغرات

تاريخ الفحص:
١٥/١/٢٠٢٦، ٩:٤٨:٢٤ ص

مدة الفحص:
N/A

الصفحات المفحوصة:
0

النماذج المفحوصة:
0

0	17	13	14	6
حرجة | Critical	عالية | High	متوسطة | Medium	منخفضة | Low	معلومات | Info

HIGH

1. Insecure Transport - No HTTPS

🔗 الرابط | URL

```
http://testphp.vulnweb.com
```

📝 الوصف | DESCRIPTION

The application is served over unencrypted HTTP

🔍 الدليل | EVIDENCE

```
Site accessible over HTTP
```

🛡️ طريقة الإصلاح | REMEDIATION

Enable HTTPS and redirect all HTTP traffic to HTTPS

📊 CVSS SCORE

CWE-319 | **7.5**

📚 المراجع | REFERENCES

https://letsencrypt.org/

https://www.ssllabs.com/ssltest/

HIGH

XXE - Potential Blind XXE .2

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

CVSS SCORE

CWE-611 | **7.5**

المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

HIGH

XXE - Potential Blind XXE .3

🔗 الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

📝 الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

🔍 الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

💉 الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

🛡️ طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

📊 CVSS SCORE

CWE-611 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

HIGH

XXE - Potential Blind XXE .4

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

CVSS SCORE

CWE-611 | **7.5**

المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

HIGH

XXE - Potential Blind XXE .5

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

CVSS SCORE

CWE-611 | **7.5**

المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

HIGH

XXE - Potential Blind XXE .6

🔗 الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

📝 الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

🔍 الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

💉 الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

🛡️ طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

📊 CVSS SCORE

CWE-611 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

7. XXE - Potential Blind XXE

HIGH

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

CVSS SCORE

CWE-611 | **7.5**

المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

8. XXE - Potential Blind XXE

HIGH

🔗 الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

📝 الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

🔍 الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

💉 الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

🛡️ طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

📊 CVSS SCORE

CWE-611 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

9. XXE - Potential Blind XXE

HIGH

🔗 الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

📝 الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

🔍 الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

💉 الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

🛡️ طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

📊 CVSS SCORE

CWE-611 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

HIGH

10. XXE - Potential Blind XXE

🔗 الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

📝 الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

🔍 الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

💉 الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

🛡️ طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

📊 CVSS SCORE

CWE-611 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

HIGH

11. XXE - Potential Blind XXE

🔗 الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

📝 الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

🔍 الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

💉 الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

🛡️ طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

📊 CVSS SCORE

CWE-611 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

12. XXE - Potential Blind XXE

HIGH

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

CVSS SCORE

CWE-611 | **7.5**

المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

HIGH

13. XXE - Potential Blind XXE

🔗 الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

📝 الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

🔍 الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

💉 الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

🛡️ طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

📊 CVSS SCORE

CWE-611 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

HIGH

XXE - Potential Blind XXE .14

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

CVSS SCORE

CWE-611 | **7.5**

المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

HIGH

XXE - Potential Blind XXE .15

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

CVSS SCORE

CWE-611 | **7.5**

المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

16. XXE - Potential Blind XXE

HIGH

🔗 الرابط | URL

```
http://testphp.vulnweb.com
```

📝 الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

🔍 الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

💉 الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

🛡️ طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

📊 CVSS SCORE

CWE-611 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

17. XXE - Potential Blind XXE

HIGH

🔗 الرابط | URL

```
http://testphp.vulnweb.com
```

📝 الوصف | DESCRIPTION

.The application may be vulnerable to blind XXE attacks

🔍 الدليل | EVIDENCE

```
Error message indicates XXE processing: <!DOCTYPE HTML PUBLIC "-//
"W3C//DTD HTML 4.01 Transitional//EN
http://www.w3.org/TR/html4/loose.dtd"
```

💉 الحمولة | PAYLOAD

```
Blind XXE with external DTD
```

🛡️ طريقة الإصلاح | REMEDIATION

.Disable external entity and DTD processing

📊 CVSS SCORE

CWE-611 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/xxe/blind

MEDIUM

18. Missing Security Header - X-CONTENT-TYPE-OPTIONS

🔗 الرابط | URL

```
http://testphp.vulnweb.com
```

📝 الوصف | DESCRIPTION

X-Content-Type-Options header not set

🔍 الدليل | EVIDENCE

```
Header "x-content-type-options" not found in response
```

🛡️ طريقة الإصلاح | REMEDIATION

Set X-Content-Type-Options: nosniff

📊 CVSS SCORE

CWE-16 | 5

📚 المراجع | REFERENCES

https://owasp.org/www-project-secure-headers/

https://securityheaders.com/

19. Missing Security Header - X-FRAME-OPTIONS

MEDIUM

الرابط | URL

```
http://testphp.vulnweb.com
```

الوصف | DESCRIPTION

X-Frame-Options header not set

الدليل | EVIDENCE

```
Header "x-frame-options" not found in response
```

طريقة الإصلاح | REMEDIATION

Set X-Frame-Options: DENY or SAMEORIGIN

CVSS SCORE

CWE-1021 | 5

المراجع | REFERENCES

https://owasp.org/www-project-secure-headers/

https://securityheaders.com/

MEDIUM

20. Missing Security Header - CONTENT-SECURITY-POLICY

🔗 الرابط | URL

```
http://testphp.vulnweb.com
```

📝 الوصف | DESCRIPTION

Content-Security-Policy header not set

🔍 الدليل | EVIDENCE

```
Header "content-security-policy" not found in response
```

🛡️ طريقة الإصلاح | REMEDIATION

Implement a strict Content Security Policy

📊 CVSS SCORE

CWE-16 | 5

📚 المراجع | REFERENCES

https://owasp.org/www-project-secure-headers/

https://securityheaders.com/

21. Clickjacking - No Frame Protection

MEDIUM

🔗 الرابط | URL

```
http://testphp.vulnweb.com
```

📝 الوصف | DESCRIPTION

Page can be embedded in iframes on any domain, enabling clickjacking attacks.

🔍 الدليل | EVIDENCE

```
Missing X-Frame-Options and CSP frame-ancestors
```

🛡️ طريقة الإصلاح | REMEDIATION

Add X-Frame-Options: DENY or SAMEORIGIN header. Better yet, use CSP frame-ancestors directive.

📊 CVSS SCORE

CWE-1021 | 4.3

📚 المراجع | REFERENCES

https://owasp.org/www-community/attacks/Clickjacking
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
https://portswigger.net/web-security/clickjacking

MEDIUM

22. Information Disclosure - Admin Panel Exposure

الرابط | URL

```
http://testphp.vulnweb.com/admin
```

الوصف | DESCRIPTION

.Administrative interface is accessible. Should be restricted to authorized users

الدليل | EVIDENCE

```
Admin panel found at /admin
```

طريقة الإصلاح | REMEDIATION

.Restrict access to admin panels via IP whitelisting or VPN

CVSS SCORE

CWE-200 | **5**

المراجع | REFERENCES

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/02-Configuration_and_Deployment_Management_Testing/05-Enumerate_Infrastructure_and_Application_Admin_Interfaces

MEDIUM

23. Information Disclosure - Admin Panel Exposure

🔗 الرابط | URL

```
http://testphp.vulnweb.com/admin/
```

📝 الوصف | DESCRIPTION

Administrative interface is accessible. Should be restricted to authorized users.

🔍 الدليل | EVIDENCE

```
Admin panel found at /admin/
```

🛡️ طريقة الإصلاح | REMEDIATION

Restrict access to admin panels via IP whitelisting or VPN.

📊 CVSS SCORE

CWE-200 | 5

📚 المراجع | REFERENCES

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/02-Configuration_and_Deployment_Management_Testing/05-Enumerate_Infrastructure_and_Application_Admin_Interfaces

24. SSRF - Potential SSRF (Timing)

MEDIUM

🔗 الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

📝 الوصف | DESCRIPTION

"SSRF vulnerability in form field "goButton

🔍 الدليل | EVIDENCE

```
Fast response (0ms) suggests server may have connected locally
```

💉 الحمولة | PAYLOAD

```
http://127.0.0.1
```

🛡️ طريقة الإصلاح | REMEDIATION

.Implement URL validation with allowlists. Block internal IP ranges

📊 CVSS SCORE

CWE-918 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/ssrf

25. SSRF - Potential SSRF (Timing)

MEDIUM

🔗 الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

📝 الوصف | DESCRIPTION

"SSRF vulnerability in form field "goButton

🔍 الدليل | EVIDENCE

```
Fast response (0ms) suggests server may have connected locally
```

💉 الحمولة | PAYLOAD

```
http://127.0.0.1
```

🛡️ طريقة الإصلاح | REMEDIATION

.Implement URL validation with allowlists. Block internal IP ranges

📊 CVSS SCORE

CWE-918 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/ssrf

26. SSRF - Potential SSRF (Timing)

MEDIUM

🔗 الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

📝 الوصف | DESCRIPTION

"SSRF vulnerability in form field "goButton

🔍 الدليل | EVIDENCE

```
Fast response (0ms) suggests server may have connected locally
```

💉 الحمولة | PAYLOAD

```
http://127.0.0.1
```

🛡️ طريقة الإصلاح | REMEDIATION

.Implement URL validation with allowlists. Block internal IP ranges

📊 CVSS SCORE

CWE-918 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/ssrf

27. SSRF - Potential SSRF (Timing)

MEDIUM

🔗 الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

📝 الوصف | DESCRIPTION

"SSRF vulnerability in form field "goButton

🔍 الدليل | EVIDENCE

```
Fast response (0ms) suggests server may have connected locally
```

💉 الحمولة | PAYLOAD

```
http://127.0.0.1
```

🛡️ طريقة الإصلاح | REMEDIATION

.Implement URL validation with allowlists. Block internal IP ranges

📊 CVSS SCORE

CWE-918 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/ssrf

28. SSRF - Potential SSRF (Timing)

MEDIUM

🔗 الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

📝 الوصف | DESCRIPTION

"SSRF vulnerability in form field "goButton

🔍 الدليل | EVIDENCE

```
Fast response (0ms) suggests server may have connected locally
```

💉 الحمولة | PAYLOAD

```
http://127.0.0.1
```

🛡️ طريقة الإصلاح | REMEDIATION

.Implement URL validation with allowlists. Block internal IP ranges

📊 CVSS SCORE

CWE-918 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/ssrf

29. SSRF - Potential SSRF (Timing)

MEDIUM

🔗 الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

📝 الوصف | DESCRIPTION

"SSRF vulnerability in form field "goButton

🔍 الدليل | EVIDENCE

```
Fast response (0ms) suggests server may have connected locally
```

💉 الحمولة | PAYLOAD

```
http://127.0.0.1
```

🛡️ طريقة الإصلاح | REMEDIATION

.Implement URL validation with allowlists. Block internal IP ranges

📊 CVSS SCORE

CWE-918 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/ssrf

30. SSRF - Potential SSRF (Timing)

MEDIUM

🔗 الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

📝 الوصف | DESCRIPTION

"SSRF vulnerability in form field "goButton

🔍 الدليل | EVIDENCE

```
Fast response (0ms) suggests server may have connected locally
```

💉 الحمولة | PAYLOAD

```
http://127.0.0.1
```

🛡️ طريقة الإصلاح | REMEDIATION

.Implement URL validation with allowlists. Block internal IP ranges

📊 CVSS SCORE

CWE-918 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/ssrf

31. Missing Security Header - X-XSS-PROTECTION

LOW

الرابط | URL

```
http://testphp.vulnweb.com
```

الوصف | DESCRIPTION

X-XSS-Protection header not set (legacy but still useful)

الدليل | EVIDENCE

```
Header "x-xss-protection" not found in response
```

طريقة الإصلاح | REMEDIATION

Set X-XSS-Protection: 1; mode=block

CVSS SCORE

CWE-79 | 3

المراجع | REFERENCES

https://owasp.org/www-project-secure-headers/

https://securityheaders.com/

32. Missing Security Header - REFERRER-POLICY

LOW

الرابط | URL

```
http://testphp.vulnweb.com
```

الوصف | DESCRIPTION

Referrer-Policy header not set

الدليل | EVIDENCE

```
Header "referrer-policy" not found in response
```

طريقة الإصلاح | REMEDIATION

Set Referrer-Policy: strict-origin-when-cross-origin

CVSS SCORE

CWE-200 | 3

المراجع | REFERENCES

https://owasp.org/www-project-secure-headers/

https://securityheaders.com/

33. Missing Security Header - PERMISSIONS-POLICY

LOW

الرابط | URL

```
http://testphp.vulnweb.com
```

الوصف | DESCRIPTION

Permissions-Policy header not set

الدليل | EVIDENCE

```
Header "permissions-policy" not found in response
```

طريقة الإصلاح | REMEDIATION

Define a Permissions-Policy to control browser features

CVSS SCORE

CWE-16 | 3

المراجع | REFERENCES

https://owasp.org/www-project-secure-headers/

https://securityheaders.com/

34. XSS - potential

LOW

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

"Cross-Site Scripting (XSS) vulnerability found in form field "goButton

الدليل | EVIDENCE

```
<-- headers headers ...
<-- InstanceEndEditable --!>
<"script language="JavaScript" type="text/JavaScript>
...-!>
```

الحمولة | PAYLOAD

```
<"script/src="data:text/javascript,alert(1)>
```

طريقة الإصلاح | REMEDIATION

Implement proper input validation and output encoding. Use Content-Security-Policy headers.

CVSS SCORE

CWE-79 | **6.1**

المراجع | REFERENCES

https://portswigger.net/web-security/cross-site-scripting

https://owasp.org/www-community/attacks/xss/

35. XSS - potential

LOW

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

"Cross-Site Scripting (XSS) vulnerability found in form field "goButton

الدليل | EVIDENCE

```
<-- headers headers ...
<-- InstanceEndEditable --!>
<"script language="JavaScript" type="text/JavaScript>
...-!>
```

الحمولة | PAYLOAD

```
<script>alert("XSS")</script>
```

طريقة الإصلاح | REMEDIATION

Implement proper input validation and output encoding. Use Content-Security-Policy .headers

CVSS SCORE

CWE-79 | **6.1**

المراجع | REFERENCES

https://portswigger.net/web-security/cross-site-scripting

/https://owasp.org/www-community/attacks/xss

36. XSS - potential

LOW

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

"Cross-Site Scripting (XSS) vulnerability found in form field "searchFor

الدليل | EVIDENCE

```
<-- headers headers ...
<-- InstanceEndEditable --!>
<"script language="JavaScript" type="text/JavaScript>
...-!>
```

الحمولة | PAYLOAD

```
<script>alert(1)</script><'
```

طريقة الإصلاح | REMEDIATION

Implement proper input validation and output encoding. Use Content-Security-Policy .headers

CVSS SCORE

CWE-79 | **6.1**

المراجع | REFERENCES

https://portswigger.net/web-security/cross-site-scripting

/https://owasp.org/www-community/attacks/xss

37. XSS - potential

LOW

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

"Cross-Site Scripting (XSS) vulnerability found in form field "goButton

الدليل | EVIDENCE

```
<-- headers headers ...
<-- InstanceEndEditable --!>
<"script language="JavaScript" type="text/JavaScript>
...-!>
```

الحمولة | PAYLOAD

```
<script>alert(1)</script><'
```

طريقة الإصلاح | REMEDIATION

Implement proper input validation and output encoding. Use Content-Security-Policy .headers

CVSS SCORE

CWE-79 | **6.1**

المراجع | REFERENCES

https://portswigger.net/web-security/cross-site-scripting

/https://owasp.org/www-community/attacks/xss

38. XSS - potential

LOW

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

"Cross-Site Scripting (XSS) vulnerability found in form field "searchFor

الدليل | EVIDENCE

```
<-- headers headers ...
<-- InstanceEndEditable --!>
<"script language="JavaScript" type="text/JavaScript>
...-!>
```

الحمولة | PAYLOAD

```
<script>alert(1)</script><"
```

طريقة الإصلاح | REMEDIATION

Implement proper input validation and output encoding. Use Content-Security-Policy .headers

CVSS SCORE

CWE-79 | **6.1**

المراجع | REFERENCES

https://portswigger.net/web-security/cross-site-scripting

/https://owasp.org/www-community/attacks/xss

39. XSS - potential

LOW

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

"Cross-Site Scripting (XSS) vulnerability found in form field "goButton

الدليل | EVIDENCE

```
<-- headers headers ...
<-- InstanceEndEditable --!>
<"script language="JavaScript" type="text/JavaScript>
...-!>
```

الحمولة | PAYLOAD

```
<script>alert(1)</script>
```

طريقة الإصلاح | REMEDIATION

Implement proper input validation and output encoding. Use Content-Security-Policy .headers

CVSS SCORE

CWE-79 | **6.1**

المراجع | REFERENCES

https://portswigger.net/web-security/cross-site-scripting

/https://owasp.org/www-community/attacks/xss

40. XSS - potential

LOW

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

"Cross-Site Scripting (XSS) vulnerability found in form field "goButton

الدليل | EVIDENCE

```
<-- headers headers ...
<-- InstanceEndEditable --!>
<"script language="JavaScript" type="text/JavaScript>
...-!>
```

الحمولة | PAYLOAD

```
<scr<script>ipt>alert(1)</scr</script>ipt>
```

طريقة الإصلاح | REMEDIATION

Implement proper input validation and output encoding. Use Content-Security-Policy headers.

CVSS SCORE

CWE-79 | **6.1**

المراجع | REFERENCES

https://portswigger.net/web-security/cross-site-scripting

https://owasp.org/www-community/attacks/xss/

41. XSS - potential

LOW

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

"Cross-Site Scripting (XSS) vulnerability found in form field "searchFor

الدليل | EVIDENCE

```
<-- headers headers ...
<-- InstanceEndEditable --!>
<"script language="JavaScript" type="text/JavaScript>
...-!>
```

الحمولة | PAYLOAD

```
<data:text/html,<script>alert(1)</script
```

طريقة الإصلاح | REMEDIATION

Implement proper input validation and output encoding. Use Content-Security-Policy headers.

CVSS SCORE

CWE-79 | **6.1**

المراجع | REFERENCES

https://portswigger.net/web-security/cross-site-scripting

https://owasp.org/www-community/attacks/xss/

42. XSS - potential

LOW

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

"Cross-Site Scripting (XSS) vulnerability found in form field "goButton

الدليل | EVIDENCE

```
<-- headers headers ...
<-- InstanceEndEditable --!>
<"script language="JavaScript" type="text/JavaScript>
...-!>
```

الحمولة | PAYLOAD

```
<script>alert("XSS")</script>
```

طريقة الإصلاح | REMEDIATION

Implement proper input validation and output encoding. Use Content-Security-Policy .headers

CVSS SCORE

CWE-79 | **6.1**

المراجع | REFERENCES

https://portswigger.net/web-security/cross-site-scripting

/https://owasp.org/www-community/attacks/xss

43. XSS - potential

LOW

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

"Cross-Site Scripting (XSS) vulnerability found in form field "searchFor

الدليل | EVIDENCE

```
<-- headers headers ...
<-- InstanceEndEditable --!>
<"script language="JavaScript" type="text/JavaScript>
...-!>
```

الحمولة | PAYLOAD

```
<"script/src="data:text/javascript,alert(1)>
```

طريقة الإصلاح | REMEDIATION

Implement proper input validation and output encoding. Use Content-Security-Policy headers.

CVSS SCORE

CWE-79 | **6.1**

المراجع | REFERENCES

https://portswigger.net/web-security/cross-site-scripting

https://owasp.org/www-community/attacks/xss/

44. XSS - potential

LOW

الرابط | URL

```
http://testphp.vulnweb.com/search.php?test=query
```

الوصف | DESCRIPTION

"Cross-Site Scripting (XSS) vulnerability found in form field "goButton

الدليل | EVIDENCE

```
<-- headers headers ...
<-- InstanceEndEditable --!>
<"script language="JavaScript" type="text/JavaScript>
...-!>
```

الحمولة | PAYLOAD

```
<script>alert(1)</script><'
```

طريقة الإصلاح | REMEDIATION

Implement proper input validation and output encoding. Use Content-Security-Policy .headers

CVSS SCORE

CWE-79 | **6.1**

المراجع | REFERENCES

https://portswigger.net/web-security/cross-site-scripting

/https://owasp.org/www-community/attacks/xss

INFO

45. Information Disclosure - Server Banner

🔗 الرابط | URL

```
http://testphp.vulnweb.com
```

📝 الوصف | DESCRIPTION

Server header exposes server technology

🔍 الدليل | EVIDENCE

```
server: nginx/1.19.0
```

🛡️ طريقة الإصلاح | REMEDIATION

Remove or obscure the Server header

📊 CVSS SCORE

CWE-200 | **2**

📚 المراجع | REFERENCES

https://owasp.org/www-project-secure-headers/

46. Information Disclosure - Server Banner

INFO

🔗 الرابط | URL

```
http://testphp.vulnweb.com
```

📝 الوصف | DESCRIPTION

X-Powered-By header exposes framework information

🔍 الدليل | EVIDENCE

```
x-powered-by: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1
```

🛡️ طريقة الإصلاح | REMEDIATION

Remove the X-Powered-By header

📊 CVSS SCORE

CWE-200 | 2

📚 المراجع | REFERENCES

https://owasp.org/www-project-secure-headers/

47. Directory/File Discovery - Path Accessible

INFO

🔗 الرابط | URL

```
http://testphp.vulnweb.com/.idea/
```

📝 الوصف | DESCRIPTION

Discovered accessible path: /.idea/

🔍 الدليل | EVIDENCE

```
Path accessible: /.idea/ (Status: 200)
```

🛡️ طريقة الإصلاح | REMEDIATION

Review if this path should be publicly accessible.

📊 CVSS SCORE

CWE-200 | 1

INFO

Directory/File Discovery - Path Accessible .48

🔗 الرابط | URL

```
http://testphp.vulnweb.com/crossdomain.xml
```

📝 الوصف | DESCRIPTION

Discovered accessible path: /crossdomain.xml

🔍 الدليل | EVIDENCE

```
Path accessible: /crossdomain.xml (Status: 200)
```

🛡️ طريقة الإصلاح | REMEDIATION

.Review if this path should be publicly accessible

📊 CVSS SCORE

CWE-200 | 1

INFO

Directory/File Discovery - Path Accessible .49

🔗 الرابط | URL

```
http://testphp.vulnweb.com/clientaccesspolicy.xml
```

📝 الوصف | DESCRIPTION

Discovered accessible path: /clientaccesspolicy.xml

🔍 الدليل | EVIDENCE

```
Path accessible: /clientaccesspolicy.xml (Status: 200)
```

🛡️ طريقة الإصلاح | REMEDIATION

.Review if this path should be publicly accessible

📊 CVSS SCORE

CWE-200 | 1

50. Directory/File Discovery - Path Accessible

INFO

الرابط | URL

```
http://testphp.vulnweb.com/images/
```

الوصف | DESCRIPTION

Discovered accessible path: /images/

الدليل | EVIDENCE

```
Path accessible: /images/ (Status: 200)
```

طريقة الإصلاح | REMEDIATION

Review if this path should be publicly accessible.

CVSS SCORE

1 | CWE-200